

UTM

**UNIVERSIDAD TECNOLÓGICA
METROPOLITANA**

**TECNOLOGÍAS DE LA INFORMACIÓN INNOVACIÓN
DIGITAL**

Actividad:

Reglamento para una empresa de Desarrollo de Software

Materia:

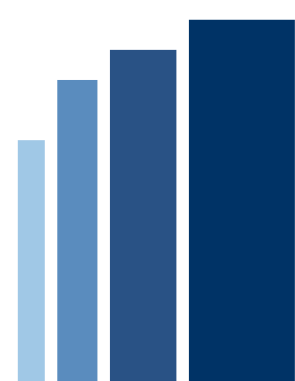
Ética y Legislación en Tecnologías de la Información

Maestro: Mirian Magaly Canche Caamal

Integrantes: Jesús Guadalupe Canul

Grado: 7° Cuatrimestre

Grupo: A



Reglamento para una Empresa de Desarrollo de Software

Equipo: Jesús Guadalupe Canul, Cocom Pech Brian Alberto, Tun Cauich
Brandon Andrei

Reglamento de Jesús Guadalupe Canul

Sección I — Empleados

Artículo 1. Todo empleado deberá cumplir con un horario laboral de 8 horas diarias, respetando los horarios de entrada y salida establecidos por la empresa.

Artículo 2. Los empleados están obligados a mantener la confidencialidad de la información interna de la empresa, proyectos en desarrollo y datos de los clientes.

Artículo 3. Se prohíbe el uso de recursos tecnológicos de la empresa para fines personales durante el horario laboral.

Artículo 4. Todo empleado deberá participar en las capacitaciones programadas por la empresa para mantenerse actualizado en tecnologías y buenas prácticas.

Artículo 5. El incumplimiento reiterado de las normas será motivo de sanciones que pueden ir desde amonestaciones escritas hasta la rescisión del contrato.

Sección II — Usuarios

Artículo 6. Los usuarios deberán utilizar el software únicamente para los fines establecidos en el contrato de licencia o términos de uso.

Artículo 7. Queda prohibida la ingeniería inversa, descompilación o modificación no autorizada del software proporcionado.

Artículo 8. Los usuarios son responsables de mantener la seguridad de sus credenciales de acceso y no compartirlas con terceros.

Artículo 9. Cualquier vulnerabilidad o error detectado deberá ser reportado a la empresa a través de los canales oficiales de soporte.

Artículo 10. La empresa no se hace responsable por el uso indebido del software por parte del usuario.

Sección III — Desarrolladores

Artículo 11. Todo desarrollador deberá seguir los estándares de codificación y las convenciones de nombrado definidas por el equipo de arquitectura.

Artículo 12. El código fuente deberá documentarse de manera clara y se deberá utilizar un sistema de control de versiones (Git) para todos los proyectos.

Artículo 13. Los desarrolladores deberán realizar pruebas unitarias y de integración antes de enviar cualquier cambio al repositorio principal.

Artículo 14. Queda prohibido utilizar bibliotecas o frameworks con licencias incompatibles con los términos del proyecto sin autorización previa.

Artículo 15. Los desarrolladores deberán reportar el avance de sus tareas diariamente mediante las herramientas de gestión de proyectos establecidas.

Reglamento de Cocom Pech Brian Alberto

Sección I — Empleados

Artículo 1. Los empleados deberán portar identificación oficial de la empresa en todo momento dentro de las instalaciones.

Artículo 2. Se establece un código de vestimenta casual profesional; no se permite ropa con mensajes ofensivos o inapropiados.

Artículo 3. Todo empleado tiene derecho a un ambiente laboral libre de acoso, discriminación y violencia.

Artículo 4. Las faltas injustificadas se sancionarán con descuento proporcional del salario y, tras tres faltas consecutivas, se procederá a la rescisión del contrato.

Artículo 5. Los empleados podrán realizar trabajo remoto previa autorización de su jefe directo, cumpliendo con los entregables establecidos.

Sección II — Usuarios

Artículo 6. Los usuarios recibirán capacitación inicial gratuita sobre el uso del software adquirido.

Artículo 7. Los usuarios deberán aceptar los términos y condiciones antes de utilizar cualquier producto de la empresa.

Artículo 8. La empresa garantiza soporte técnico dentro de un plazo máximo de 48 horas hábiles tras recibir un reporte.

Artículo 9. Los datos personales de los usuarios serán tratados conforme a la Ley Federal de Protección de Datos Personales en Posesión de Particulares.

Artículo 10. Queda prohibido el uso del software para actividades ilícitas; la empresa se reserva el derecho de suspender el servicio en tales casos.

Sección III — Desarrolladores

Artículo 11. Los desarrolladores tendrán acceso exclusivo a los repositorios de los proyectos en los que están asignados.

Artículo 12. Toda funcionalidad nueva deberá pasar por un proceso de revisión de código (code review) antes de integrarse.

Artículo 13. Los desarrolladores deberán respetar los plazos de entrega acordados en la planificación de sprints.

Artículo 14. Se prohíbe el uso de credenciales hardcodeadas en el código fuente; se deberán usar variables de entorno o gestores de secretos.

Artículo 15. Los desarrolladores tienen la obligación de mantenerse actualizados mediante autoformación y participación en comunidades técnicas.

Reglamento de Tun Cauich Brandon Andrei

Sección I — Empleados

Artículo 1. Todo empleado firmará un contrato de confidencialidad (NDA) al momento de su contratación.

Artículo 2. Se otorgarán 15 días de vacaciones al año, más los días festivos oficiales establecidos por la ley.

Artículo 3. La empresa proporcionará el equipo de cómputo necesario para las labores del empleado; el uso personal del mismo queda bajo responsabilidad del trabajador.

Artículo 4. Queda estrictamente prohibido compartir información de la empresa en redes sociales sin autorización del departamento de comunicación.

Artículo 5. Los empleados deberán respetar la propiedad intelectual de la empresa; todo desarrollo realizado durante la relación laboral pertenece a la compañía.

Sección II — Usuarios

Artículo 6. Los usuarios podrán solicitar la eliminación de sus datos personales en cualquier momento, conforme al derecho de supresión.

Artículo 7. El software se entrega "tal cual" (as-is); la empresa no garantiza que esté libre de errores al 100%.

Artículo 8. Los usuarios no podrán redistribuir, revender ni sublicenciar el software sin autorización escrita de la empresa.

Artículo 9. La empresa se reserva el derecho de actualizar el software y modificar funcionalidades, notificando con al menos 30 días de anticipación.

Artículo 10. En caso de disputa, las partes se someterán a un proceso de mediación antes de recurrir a instancias legales.

Sección III — Desarrolladores

Artículo 11. Los desarrolladores deberán seguir la metodología ágil (Scrum) establecida por la empresa para la gestión de proyectos.

Artículo 12. Todo código deberá cumplir con los estándares de seguridad OWASP antes de ser desplegado en producción.

Artículo 13. Los desarrolladores no podrán instalar software no autorizado en los equipos de la empresa.

Artículo 14. Se realizarán evaluaciones de desempeño trimestrales para medir la productividad y calidad del código entregado.

Artículo 15. En caso de detección de malas prácticas de programación (como omitir pruebas o ignorar vulnerabilidades conocidas), se aplicarán sanciones progresivas.

Reglamento Unificado del Equipo

A continuación se presenta el reglamento unificado, resultado de integrar las propuestas de los tres integrantes, eliminando redundancias y armonizando las disposiciones.

Sección I — Empleados

Artículo 1. Todo empleado firmará un contrato de confidencialidad (NDA) al momento de su contratación y mantendrá la reserva de información interna, proyectos y datos de clientes durante y después de la relación laboral.

Artículo 2. El horario laboral será de 8 horas diarias. Se permite el trabajo remoto previa autorización del jefe directo, siempre que se cumplan los entregables.

Artículo 3. Los empleados deberán portar identificación oficial dentro de las instalaciones y mantener un código de vestimenta casual profesional.

Artículo 4. La empresa garantiza un ambiente laboral libre de acoso, discriminación y violencia. Cualquier conducta contraria será sancionada.

Artículo 5. La empresa proporcionará el equipo de cómputo necesario. Se prohíbe el uso de recursos tecnológicos de la empresa para fines personales durante el horario laboral.

Artículo 6. Los empleados deberán participar en las capacitaciones programadas para mantenerse actualizados.

Artículo 7. Queda prohibido compartir información de la empresa en redes sociales sin autorización del departamento de comunicación.

Artículo 8. Todo desarrollo realizado durante la relación laboral es propiedad intelectual de la empresa.

Artículo 9. Se otorgarán 15 días de vacaciones al año, más los días festivos oficiales.

Artículo 10. Las faltas injustificadas se sancionarán con descuento salarial proporcional. Tres faltas consecutivas injustificadas serán motivo de rescisión de contrato. El incumplimiento reiterado de normas se sancionará de forma progresiva.

Sección II — Usuarios

Artículo 11. Los usuarios deberán aceptar los términos y condiciones antes de utilizar cualquier producto de la empresa y utilizar el software únicamente para los fines establecidos.

Artículo 12. Queda prohibida la ingeniería inversa, descompilación, redistribución, reventa o sublicenciamiento del software sin autorización escrita.

Artículo 13. Los usuarios son responsables de la seguridad de sus credenciales de acceso y no deberán compartirlas con terceros.

Artículo 14. Los datos personales serán tratados conforme a la Ley Federal de Protección de Datos Personales. Los usuarios podrán solicitar la eliminación de sus datos en cualquier momento.

Artículo 15. Los usuarios recibirán capacitación inicial sobre el uso del software adquirido.

Artículo 16. Cualquier vulnerabilidad o error deberá reportarse por los canales oficiales de soporte. La empresa garantiza respuesta en un plazo máximo de 48 horas hábiles.

Artículo 17. La empresa se reserva el derecho de actualizar el software y modificar funcionalidades, notificando con al menos 30 días de anticipación.

Artículo 18. El uso del software para actividades ilícitas resultará en la suspensión inmediata del servicio.

Artículo 19. En caso de disputa, las partes se someterán a mediación antes de recurrir a instancias legales.

Sección III — Desarrolladores

Artículo 20. Los desarrolladores seguirán los estándares de codificación, convenciones de nombrado y la metodología ágil (Scrum) definidos por la empresa.

Artículo 21. Todo código deberá documentarse, versionarse con Git y cumplir con los estándares de seguridad OWASP antes de desplegarse.

Artículo 22. Se deberán realizar pruebas unitarias y de integración. Toda funcionalidad nueva pasará por revisión de código (code review) antes de integrarse.

Artículo 23. Los desarrolladores tendrán acceso exclusivo a los repositorios de los proyectos en los que están asignados.

Artículo 24. Se prohíbe el uso de bibliotecas con licencias incompatibles, credenciales hardcodedas en el código y la instalación de software no autorizado.

Artículo 25. Los desarrolladores reportarán avances diariamente y respetarán los plazos de los sprints.

Artículo 26. Se realizarán evaluaciones de desempeño trimestrales. Las malas prácticas de programación (omitir pruebas, ignorar vulnerabilidades) se sancionarán de forma progresiva.

Artículo 27. Los desarrolladores tienen la obligación de mantenerse actualizados mediante autoformación, participación en comunidades técnicas y capacitaciones de la empresa.

Análisis Comparativo

¿Qué hizo falta?

- Jesús: No incluyó reglas sobre vestimenta, identificación ni vacaciones para empleados. No mencionó protección de datos personales de usuarios ni capacitación inicial.
- Brando: No estableció horario laboral específico ni políticas de propiedad intelectual para empleados. No incluyó estándares de seguridad (OWASP) para desarrolladores.
- Brandon: No definió normas sobre ambiente laboral libre de acoso ni capacitaciones obligatorias para empleados. No mencionó soporte técnico con tiempos de respuesta para usuarios.
- En general: Ninguno incluyó procedimientos de contratación/despido detallados, políticas de home office formales, ni un mecanismo claro de resolución de conflictos internos entre empleados.

¿Qué está de más?

- La regla de Jesús sobre prohibir uso personal de recursos es muy restrictiva cuando Brando y Brandon permiten cierta flexibilidad (trabajo remoto, equipo bajo responsabilidad del empleado).
- La cláusula 'as-is' de Brandon podría resultar excesiva para una empresa que también ofrece soporte técnico garantizado (como propone Brando con las 48 horas).
- Tener tres secciones idénticas de estructura (empleados, usuarios, desarrolladores) por persona genera repetición innecesaria en el documento individual.

¿Qué cosas son contradictorias?

- Jesús dice que la empresa NO se hace responsable del uso indebido del software, mientras que Brando dice que la empresa SUSPENDERÁ el servicio si hay uso ilícito. Esto implica distintos niveles de responsabilidad de la empresa.
- Brandon dice que el software se entrega 'tal cual' sin garantía, pero Brando establece soporte técnico obligatorio en 48 horas. Si no hay garantía de funcionamiento, ¿por qué hay obligación de soporte?
- Jesús prohíbe estrictamente el uso personal de recursos de la empresa, pero Brandon dice que el equipo proporcionado queda 'bajo responsabilidad del trabajador', lo que implica cierta libertad de uso.
- Jesús exige reportes diarios de avance, mientras que Brandon habla de evaluaciones trimestrales, lo que puede generar confusión sobre la frecuencia real de seguimiento (el unificado los armoniza incluyendo ambos).

Elementos Fundamentales de la Ética en el Reglamento

A continuación se analiza cómo el reglamento unificado incorpora los cinco elementos fundamentales de la ética aplicada a las tecnologías de la información.

1. Privacidad

La privacidad es el derecho de toda persona a controlar su información personal y decidir qué datos comparte, con quién y bajo qué condiciones. En el contexto del desarrollo de software, la privacidad implica proteger los datos de los usuarios contra accesos no autorizados, usos indebidos y exposiciones innecesarias. El reglamento unificado aborda este elemento en el Artículo 14, que establece el tratamiento de datos personales conforme a la Ley Federal de Protección de Datos Personales en Posesión de Particulares, y reconoce el derecho de los usuarios a solicitar la eliminación de sus datos. Asimismo, el Artículo 1 obliga a los empleados a firmar un NDA que protege la información confidencial de la empresa y sus clientes.

2. Seguridad

La seguridad se refiere a las medidas técnicas y organizacionales para proteger los sistemas, datos e infraestructura contra amenazas, vulnerabilidades y ataques. En una empresa de desarrollo de software, garantizar la seguridad es una responsabilidad ética fundamental. El reglamento refleja este principio en el Artículo 21, que exige el cumplimiento de los estándares OWASP antes de desplegar código en producción; en el Artículo 24, que prohíbe credenciales hardcodeadas en el código fuente; en el Artículo 13, que responsabiliza a los usuarios de proteger sus credenciales de acceso; y en el Artículo 16, que establece canales de reporte de vulnerabilidades con tiempos de respuesta garantizados.

3. Responsabilidad

La responsabilidad ética implica que cada actor (empleado, desarrollador, usuario) debe asumir las consecuencias de sus acciones y actuar con diligencia en el cumplimiento de sus obligaciones. El reglamento incorpora este principio transversalmente: el Artículo 10 establece sanciones progresivas por incumplimiento de normas; el Artículo 26 implementa evaluaciones de desempeño trimestrales para desarrolladores; el Artículo 22 exige pruebas y revisiones de código antes de integrar

cambios; y el Artículo 18 advierte que el uso ilícito del software resultará en suspensión del servicio. La responsabilidad no es solo individual sino también corporativa, como lo refleja el compromiso de soporte técnico en 48 horas.

4. Propiedad Intelectual

La propiedad intelectual protege las creaciones del intelecto humano, incluyendo el código fuente, diseños, algoritmos y documentación producidos en el ámbito del desarrollo de software. Respetar la propiedad intelectual es un deber ético que evita el plagio, la apropiación indebida y el uso no autorizado de creaciones ajenas. El reglamento aborda este tema en el Artículo 8, que declara que todo desarrollo realizado durante la relación laboral es propiedad de la empresa; en el Artículo 24, que prohíbe el uso de bibliotecas con licencias incompatibles; y en el Artículo 12, que impide a los usuarios redistribuir, revender o sublicenciar el software sin autorización escrita.

5. Acceso Equitativo

El acceso equitativo se refiere al derecho de todas las personas a beneficiarse de las tecnologías de la información sin discriminación por motivos económicos, geográficos, de género, edad o capacidad. Una empresa ética de desarrollo de software debe procurar que sus productos sean accesibles e inclusivos. El reglamento refleja este principio en el Artículo 4, que garantiza un ambiente laboral libre de discriminación; en el Artículo 15, que ofrece capacitación inicial gratuita a los usuarios para que puedan aprovechar el software sin importar su nivel técnico previo; y en el Artículo 6, que obliga a los empleados a participar en capacitaciones continuas, asegurando que todo el equipo tenga las mismas oportunidades de crecimiento profesional. Además, la metodología ágil (Artículo 20) promueve la colaboración horizontal y la participación equitativa de todos los desarrolladores.

Reporte de Vulnerabilidades Detectadas

A continuación se presenta el reporte de vulnerabilidades detectadas en el reglamento, siguiendo la estructura establecida en clase. Se identificaron 7 vulnerabilidades clasificadas por categoría y gravedad, cada una con su propuesta de parche.

Resumen: 4 gravedad Alta, 2 gravedad Media, 1 gravedad Baja.

Vulnerabilidad #1: NDA sin alcance ni duración definidos

1. Situación	El Artículo 1 del reglamento unificado obliga a todo empleado a firmar un contrato de confidencialidad (NDA) al momento de su contratación, pero no especifica el alcance de la información protegida, la duración de la obligación después de terminada la relación laboral, ni las consecuencias específicas por incumplimiento.
2. Artículo relacionado	Artículo 1 — Sección I (Empleados)
3. Vulnerabilidad	Un ex-empleado podría argumentar que su obligación de confidencialidad terminó junto con su contrato laboral, y divulgar información sensible de proyectos, clientes o arquitectura de software sin consecuencias legales claras.
4. Riesgo	Fuga de información confidencial, código fuente, datos de clientes o estrategias de negocio por parte de ex-empleados sin que la empresa tenga respaldo legal claro para actuar.
5. Categoría	Legal
6. Gravedad	Alta
7. Propuesta de parche	Especificar en el Artículo 1: (a) el alcance del NDA (código fuente, datos de clientes, procesos internos, arquitectura técnica), (b) la duración post-empleo (mínimo 2 años después de la separación), (c) las sanciones por incumplimiento (indemnización, acciones legales conforme a la LFPDPPP y Código Penal Federal), y (d) que el NDA debe ser un documento separado firmado por ambas partes con testigos.

Vulnerabilidad #2: Propiedad intelectual sin distinción de proyectos personales

1. Situación	El Artículo 8 declara que 'todo desarrollo realizado durante la relación laboral es propiedad intelectual de la empresa', sin distinguir entre trabajo realizado en horario laboral con recursos de la empresa y proyectos personales del empleado en su tiempo libre.
2. Artículo relacionado	Artículo 8 — Sección I (Empleados)
3. Vulnerabilidad	La redacción actual es demasiado amplia y podría interpretarse como que la empresa reclama propiedad sobre cualquier código o proyecto que el empleado desarrolle mientras esté contratado, incluso si fue creado en tiempo personal, con recursos propios y sin relación con las actividades de la empresa.
4. Riesgo	Conflictos legales con empleados que contribuyen a proyectos open source o tienen emprendimientos paralelos. Posible violación del derecho moral de autor del empleado (Ley Federal del Derecho de Autor, Art. 18-23). Desmotivación de desarrolladores talentosos que temen perder sus proyectos personales.
5. Categoría	Propiedad intelectual
6. Gravedad	Alta

7. Propuesta de parche	Reformular el Artículo 8 para especificar: 'Todo desarrollo realizado durante el horario laboral, con recursos de la empresa o relacionado con los proyectos asignados, es propiedad intelectual de la empresa. Los proyectos personales realizados fuera del horario laboral y sin uso de recursos corporativos no están sujetos a esta cláusula, siempre que no compitan directamente con los productos de la empresa ni utilicen información confidencial.'
-------------------------------	--

Vulnerabilidad #3: Protección de datos sin protocolo de brechas de seguridad

1. Situación	El Artículo 14 establece que los datos personales serán tratados conforme a la Ley Federal de Protección de Datos Personales (LFPDPPP) y que los usuarios pueden solicitar la eliminación de sus datos. Sin embargo, no se define qué sucede en caso de una brecha de seguridad, ni quién es responsable de notificar a los afectados.
2. Artículo relacionado	Artículo 14 — Sección II (Usuarios)
3. Vulnerabilidad	En caso de una filtración de datos personales de usuarios (hackeo, acceso no autorizado, error humano), el reglamento no establece un protocolo de respuesta: no define tiempos de notificación, responsable designado (DPO), canales de comunicación con afectados ni medidas de contención.
4. Riesgo	Incumplimiento del artículo 20 de la LFPDPPP que exige notificar brechas de seguridad. Multas del INAI de hasta 320,000 UMA (aprox. \$34 millones MXN). Pérdida de confianza de clientes y daño reputacional.
5. Categoría	Privacidad
6. Gravedad	Alta
7. Propuesta de parche	Agregar un Artículo 14-bis: 'En caso de brecha de seguridad que comprometa datos personales, la empresa deberá: (a) designar un Oficial de Protección de Datos responsable, (b) contener la brecha en un máximo de 24 horas, (c) notificar a los usuarios afectados y al INAI dentro de las 72 horas siguientes, (d) documentar el incidente y las medidas correctivas aplicadas, conforme a los artículos 19 y 20 de la LFPDPPP.'

Vulnerabilidad #4: Sanciones laborales sin debido proceso

1. Situación	El Artículo 10 establece descuento salarial proporcional por faltas injustificadas y rescisión de contrato tras tres faltas consecutivas. El incumplimiento reiterado de normas se sanciona 'de forma progresiva', pero no se define un procedimiento de debido proceso ni un mecanismo de apelación.
2. Artículo relacionado	Artículo 10 — Sección I (Empleados)
3. Vulnerabilidad	Un empleado sancionado no tiene mecanismo formal para presentar su defensa, aportar pruebas justificativas (emergencia médica, fuerza mayor) o apelar la decisión. Esto viola el principio de audiencia establecido en la Ley Federal del Trabajo (Art. 47).
4. Riesgo	Demandas laborales ante la Junta de Conciliación y Arbitraje por despido injustificado. La empresa podría perder el caso y pagar indemnización completa (3 meses + 20 días por año) por no haber seguido un debido proceso documentado.
5. Categoría	Laboral
6. Gravedad	Alta
7. Propuesta de parche	Reformular el Artículo 10 para incluir: 'Antes de aplicar cualquier sanción, el empleado tendrá derecho a: (a) ser notificado por escrito de la falta

	imputada, (b) presentar su defensa y pruebas en un plazo de 5 días hábiles, (c) solicitar revisión ante el comité de recursos humanos. Se levantará acta administrativa firmada por ambas partes. Las faltas por causa de fuerza mayor debidamente comprobada no se contabilizarán como injustificadas.'
--	--

Vulnerabilidad #5: Software 'as-is' contradice soporte obligatorio de 48 horas

1. Situación	El Artículo 16 garantiza respuesta de soporte técnico en un plazo máximo de 48 horas hábiles, pero en el análisis comparativo del documento se señala la contradicción con la cláusula 'as-is' que establece que el software se entrega sin garantía de funcionamiento al 100%.
2. Artículo relacionado	Artículos 16 y 17 — Sección II (Usuarios)
3. Vulnerabilidad	La contradicción entre 'no garantizamos que funcione' y 'te respondemos en 48 horas' genera ambigüedad jurídica. Un usuario podría exigir soporte para funcionalidades que la empresa no garantiza, o la empresa podría negar soporte amparándose en la cláusula 'as-is' y dejar sin efecto el compromiso de 48 horas.
4. Riesgo	Demandas por incumplimiento contractual. Pérdida de clientes por expectativas no cumplidas. El reglamento se vuelve inaplicable en disputas legales por la contradicción interna.
5. Categoría	Legal
6. Gravedad	Media
7. Propuesta de parche	Clarificar en el Artículo 16: 'La empresa garantiza respuesta de soporte técnico en 48 horas hábiles para incidentes reportados por los canales oficiales. El soporte cubre: errores reproducibles, fallos de seguridad y problemas de acceso. No cubre: funcionalidades no documentadas, personalizaciones fuera del alcance contratado ni incompatibilidades con software de terceros.' Eliminar la referencia genérica 'as-is' y sustituir por un listado claro de exclusiones.

Vulnerabilidad #6: Uso de IA no regulado en el desarrollo

1. Situación	El reglamento no contiene ninguna disposición sobre el uso de herramientas de inteligencia artificial (GitHub Copilot, ChatGPT, Claude, etc.) en el proceso de desarrollo de software, ni establece políticas sobre la revisión del código generado por IA.
2. Artículo relacionado	No existe — Sección III (Desarrolladores)
3. Vulnerabilidad	Los desarrolladores podrían usar herramientas de IA para generar código sin revisión adecuada, introduciendo vulnerabilidades de seguridad, código con licencias incompatibles (entrenado con código GPL), o enviando código propietario de la empresa a servidores externos (prompts con código fuente confidencial).
4. Riesgo	Filtración de código fuente confidencial a través de prompts en herramientas de IA externas. Introducción de vulnerabilidades no detectadas en código generado automáticamente. Posibles violaciones de licencias de software. Problemas de propiedad intelectual sobre código generado por IA.
5. Categoría	Uso de IA
6. Gravedad	Media
7. Propuesta de parche	Agregar un nuevo Artículo 28: 'El uso de herramientas de inteligencia artificial para generación de código está permitido bajo las siguientes condiciones: (a) no se enviará código fuente propietario como prompt a

	herramientas de IA externas, (b) todo código generado por IA debe pasar por revisión de código (code review) obligatoria, (c) se verificará que el código generado no introduzca dependencias con licencias incompatibles, (d) se documentará el uso de IA en los commits correspondientes.'
--	--

Vulnerabilidad #7: Definición vaga de 'uso personal' de recursos

1. Situación	El Artículo 5 prohíbe el uso de recursos tecnológicos de la empresa para fines personales durante el horario laboral, pero no define qué constituye 'uso personal' ni establece excepciones razonables.
2. Artículo relacionado	Artículo 5 — Sección I (Empleados)
3. Vulnerabilidad	La prohibición absoluta de uso personal es ambigua y poco realista. ¿Revisar un correo personal durante el almuerzo es una violación? ¿Usar el navegador para una consulta médica? Sin definición clara, la regla es inaplicable o se aplica de forma arbitraria.
4. Riesgo	Aplicación selectiva y arbitraria de la norma, generando un ambiente laboral hostil. Posibles demandas por discriminación si se sanciona a unos empleados y no a otros por la misma conducta. Desmotivación del equipo por reglas percibidas como excesivas.
5. Categoría	Ético
6. Gravedad	Baja
7. Propuesta de parche	Reformular el Artículo 5: 'Se permite el uso personal breve e incidental de los recursos tecnológicos (consultas personales, comunicación familiar urgente) siempre que no interfiera con las funciones laborales ni comprometa la seguridad de la información. Queda estrictamente prohibido: descargar software no autorizado, acceder a contenido inapropiado, usar los equipos para actividades comerciales ajenas a la empresa o almacenar archivos personales en servidores corporativos.'

Parches Aplicados al Reglamento

Con base en las vulnerabilidades de mayor gravedad detectadas, se presentan los siguientes tres parches que mejoran, especifican y amplían las reglas del reglamento unificado.

Parche 1: Artículo 1 — NDA con alcance y duración definidos

Versión original:

"Todo empleado firmará un contrato de confidencialidad (NDA) al momento de su contratación y mantendrá la reserva de información interna, proyectos y datos de clientes durante y después de la relación laboral."

Versión parcheada:

"Artículo 1. Todo empleado firmará un contrato de confidencialidad (NDA) al momento de su contratación. Dicho contrato deberá especificar:

- a) Alcance: la obligación cubre código fuente, datos de clientes, procesos internos, arquitectura técnica, estrategias comerciales y cualquier información clasificada como confidencial.
- b) Duración: la obligación de confidencialidad permanecerá vigente durante la relación laboral y por un periodo mínimo de 2 (dos) años posteriores a la terminación del contrato.
- c) Sanciones: el incumplimiento dará lugar a indemnización por daños y perjuicios, así como acciones legales conforme a la LFPDPPP y el Código Penal Federal.
- d) El NDA será un documento independiente, firmado por ambas partes ante dos testigos, con copia para el empleado."

Justificación: La versión original no definía alcance, duración post-empleo ni consecuencias, lo que permitiría a un ex-empleado divulgar información sensible sin respaldo legal claro para la empresa. El parche cierra esta vulnerabilidad con especificaciones concretas alineadas a la legislación mexicana vigente.

Parche 2: Artículo 14-bis — Protocolo de brechas de seguridad (nuevo)

Artículo original (14):

"Los datos personales serán tratados conforme a la Ley Federal de Protección de Datos Personales. Los usuarios podrán solicitar la eliminación de sus datos en cualquier momento."

Nuevo Artículo 14-bis (agregado):

"Artículo 14-bis. Protocolo de respuesta ante brechas de seguridad de datos personales. En caso de que se detecte una brecha de seguridad que comprometa datos personales de usuarios, la empresa deberá:

- a) Designar un Oficial de Protección de Datos (DPO) como responsable de coordinar la respuesta.
- b) Contener la brecha y mitigar el daño en un plazo máximo de 24 horas desde su detección.
- c) Notificar a los usuarios afectados por correo electrónico y a través de los canales oficiales dentro de las 72 horas siguientes a la detección.

- d) Reportar el incidente al Instituto Nacional de Transparencia (INAI) conforme al artículo 20 de la LFPDPPP.
- e) Documentar el incidente en un registro interno que incluya: causa, datos comprometidos, usuarios afectados, acciones de contención y medidas preventivas implementadas.
- f) Realizar una auditoría de seguridad dentro de los 30 días posteriores al incidente."

Justificación: El reglamento original menciona la LFPDPPP pero no define qué hacer en caso de brecha de seguridad. Sin este protocolo, la empresa se expone a multas del INAI de hasta 320,000 UMA (aproximadamente \$34 millones MXN) y a la pérdida de confianza de sus clientes. Este artículo nuevo cubre la obligación legal y establece un proceso claro de respuesta.

Parche 3: Artículo 10 — Sanciones con debido proceso

Versión original:

"Las faltas injustificadas se sancionarán con descuento salarial proporcional. Tres faltas consecutivas injustificadas serán motivo de rescisión de contrato. El incumplimiento reiterado de normas se sancionará de forma progresiva."

Versión parcheada:

"Artículo 10. Régimen de sanciones y debido proceso.

Las faltas injustificadas se sancionarán con descuento salarial proporcional. Tres faltas consecutivas injustificadas serán motivo de rescisión de contrato. El incumplimiento reiterado de normas se sancionará de forma progresiva.

Antes de aplicar cualquier sanción, se garantiza el siguiente procedimiento:

- a) El empleado será notificado por escrito de la falta imputada, describiendo los hechos, la fecha y la norma presuntamente incumplida.
- b) El empleado dispondrá de 5 (cinco) días hábiles para presentar su defensa por escrito y aportar las pruebas que considere pertinentes.
- c) El empleado podrá solicitar revisión de su caso ante el comité de Recursos Humanos.
- d) Se levantará acta administrativa firmada por ambas partes y un testigo.
- e) Las faltas por causa de fuerza mayor debidamente comprobada (emergencia médica, desastre natural, fallecimiento de familiar directo) no se contabilizarán como injustificadas.

Las sanciones progresivas serán: (1) amonestación verbal, (2) amonestación escrita, (3) suspensión temporal sin goce de sueldo de 1 a 3 días, (4) rescisión de contrato."

Justificación: La versión original no contemplaba ningún mecanismo de defensa para el empleado, violando el principio de audiencia de la Ley Federal del Trabajo (Art. 47). Sin debido proceso, cualquier despido podría ser declarado injustificado por la Junta de Conciliación y Arbitraje, obligando a la empresa a pagar indemnización completa. El parche establece un proceso claro, documentado y justo que protege tanto al empleado como a la empresa.